

A decorative frame composed of two thick, light-colored L-shaped lines. One line starts at the top-left and extends horizontally to the right, then vertically down. The other line starts at the bottom-right and extends horizontally to the left, then vertically up. They meet in the center, framing the text.

XSS-ИНЪЕКЦИИ

XSS атака

XSS (межсайтовый скриптинг) – одна из разновидностей атак на веб-системы, которая подразумевает внедрение вредоносного кода на определенную страницу сайта и взаимодействие этого кода с удаленным сервером злоумышленников при открытии страницы пользователем.

Термин с английского расшифровывается как **Cross-Site Scripting**, но при этом получил аббревиатуру **XSS**, чтобы не было путаницы с CSS (каскадные таблицы стилей).

Как работает межсайтовый скриптинг

Основная цель межсайтового скриптинга – кража cookies пользователей при помощи встроенного на сервере скрипта с дальнейшей выборкой необходимых данных и использованием их для последующих атак и взломов. Злоумышленник осуществляет атаку пользователей не напрямую, а с использованием уязвимостей веб-сайта, который посещают жертвы, и внедряет специальный JavaScript. В браузере у пользователей этот код отображается как единая часть сайта. При этом посещаемый ресурс по факту является соучастником XSS-атаки.

Как работает межсайтовый скриптинг

Если сравнивать с SQL-инъекциями, то XSS безопасен для сервера, но несет угрозу для пользователей зараженного ресурса или страницы. Однако, если к злоумышленнику попадут cookies администратора, можно получить доступ к панели управления сайтом и его содержимому.

Методика атаки через XSS

Запуск вредоносного кода JavaScript возможен только в браузере жертвы, поэтому сайт, на который зайдет пользователь, должен иметь уязвимость к XSS. Для совершения атаки злоумышленник изначально проверяет ресурсы на наличие уязвимостей через XSS, используя автоматизированные скрипты или ручной режим поиска. Обычно это стандартные формы, которые могут отправлять и принимать запросы (комментарии, поиск, обратная связь).

Методика атаки через XSS

Проводится полный сбор страниц с формами ввода, и каждая сканируется на наличие уязвимостей. Например, у нас есть страница «Поиск» на сайте. Для проверки уязвимости XSS достаточно ввести запрос:

```
<script>alert("cookie: "+document.cookie)</script>
```

Методика атаки через XSS

Если на экране появится уведомление, значит вы обнаружили брешь в безопасности. В противном случае система отобразит вам страницу с результатами поиска. Основные популярные CMS уже давно лишились подобных проблем, но из-за возможности расширения функционала за счет модулей и плагинов, создаваемых сторонними разработчиками, шансы на использование уязвимостей XSS возрастают в разы, особенно в Joomla, DLE, Bitrix, Wordpress.

Методика атаки через XSS

Если страница имеет уязвимости XSS, на экране появится уведомление такого же плана, как и в первом случае.

Для поиска «дыр» на сайте существует огромное количество готовых скриптов и запросов, и если ни один из них не подходит, значит ресурс надежно защищен от подобных атак.

Общая классификация XSS

Четкой классификации для межсайтового скриптинга не существует, но экспертами по всему миру выделено три основных типа.

Хранимые XSS (постоянные)

Один из самых опасных типов уязвимостей, так как позволяет злоумышленнику получить доступ к серверу и уже с него управлять вредоносным кодом (удалять, модифицировать). Каждый раз при обращении к сайту выполняется заранее загруженный код, работающий в автоматическом режиме. В основном таким уязвимостям подвержены форумы, порталы, блоги, где присутствует возможность комментирования в HTML без ограничений. Вредоносные скрипты с легкостью могут быть встроены как в текст, так и в картинки, рисунки.

Отраженные XSS (непостоянные)

В этом случае вредоносная строка выступает в роли запроса жертвы к зараженному веб-сайту. Работает этот принцип по следующей схеме:

1. Злоумышленник заранее создает URL-ссылку, которая будет содержать вредоносный код и отправляет его своей жертве.
2. Она направляет этот URL-запрос на сайт (переходит по ссылке).
3. Сайт автоматически берет данные из вредоносной строки и подставляет в виде модифицированного URL-ответа жертве.
4. В итоге в браузере у жертвы выполняется вредоносный скрипт, который и содержится в ответе, а злоумышленник получает все cookies этого пользователя.

DOM-модели

В этом варианте возможно использование как хранимых XSS, так и отраженных.

Суть заключается в следующем:

1. Злоумышленник создает URL-адрес, который заранее содержит вредоносный код, и отправляет его по электронной почте или любым другим способом пользователю.
2. Человек переходит по этой ссылке, зараженный сайт принимает запрос, исключая вредоносную строку.
3. На странице у пользователя выполняется сценарий, в результате чего загружается вредоносный скрипт, и злоумышленник получает cookies.

Виды XSS по способу взаимодействия

Так как основная цель злоумышленника – запустить вредоносный скрипт на компьютере жертвы, существует еще и два основных типа XSS-атак по способу взаимодействия.

Пассивные

От жертвы требуется определенное действие, чтобы вызвать обработчик событий и запустить вредоносный скрипт в установленной форме. Для этого используется социальная инженерия, например, отправка электронного письма с призывом перейти по ссылке и нажать на определенную область на сайте. Как только пользователь наведет на нужный объект и кликнет по нему, запустится вредоносный скрипт. Если же жертва бездействует, код не будет активирован.

АКТИВНЫЕ

Злоумышленнику не нужно заманивать жертву по специальным ссылкам, так как код встраивается в базах данных или в каком-нибудь исполняемом файле на сервере. От пользователя не требуется никакой активности. У форм ввода, как правило, установлен специальный обработчик событий, автоматически активирующийся при попадании на эту страничку. В итоге все пользователи, перешедшие по этой ссылке, станут жертвами злоумышленника.

Как проверить сайт на наличие уязвимостей XSS и защитить его

Для быстрой проверки сайта на наличие уязвимостей XSS можно воспользоваться специализированными сервисами, которые в автоматическом режиме проведут сканирование страницы. В обязательном порядке нужно проверять все URL, где возможна отправка данных со стороны пользователя (формы комментариев, обратная связь, поиск). В качестве примера можете использовать <http://xss-scanner.com>, но не стоит ограничиваться лишь одним инструментом.

Как проверить сайт на наличие уязвимостей XSS и защитить его

Подобные сервисы не дают полной гарантии успеха, поэтому рекомендуем проверять найденные страницы в ручном режиме и обязательно исключить все опасные спецсимволы, заменив их безопасными. Речь идет о скобках `<` и `>`, в которых и прописываются все зарезервированные языком html-запросы и теги.

Как проверить сайт на наличие уязвимостей XSS и защитить его

Несколько советов по предотвращению использования XSS на вашем сайте:

1. Если на вашем сайте включен пользовательский ввод, должно выполняться кодирование.
2. Если кодирование невозможно или неуместно в некоторых ситуациях, заменяйте его или дополняйте валидацией.
3. Безопасная обработка данных должна выполняться в коде не только на стороне вашего web-сервера, но и на стороне пользователя (клиента).
4. Если используете популярные CMS, например Wordpress, Bitrix, Joomla, регулярно обновляйте версии движка и всех установленных модулей и плагинов. По умолчанию большинство самых распространенных систем для управления сайтами защищены от использования XSS, а вот сторонние плагины из непроверенных источников могут содержать уязвимости.